

ISO/IEC 42001:2023 - Manual Prático do Sistema de Gestão de Inteligência Artificial

Implementação de um SGIA baseado em risco

Autor e diretor do projeto: Alberto (AI) Leiva

Edição em português do Brasil (pt-BR)

Versão 1.0 - Julho de 2026

Aviso importante: material educacional. Verifique informações atuais em fontes oficiais e obtenha orientação profissional quando necessário.

Como usar este manual

- Use como referência para planejamento, avaliação, implementação e auditoria.
- Adapte os controles ao risco, porte, setor, arquitetura e obrigações da organização.
- Registre decisões, exceções, evidências e responsáveis.
- Confirme recursos e nomenclaturas atuais na documentação oficial.

1. Objetivo e escopo

Este manual apresenta orientação prática para proteger sistemas de inteligência artificial em ambientes empresariais. Ele integra governança, gestão de riscos, segurança, privacidade, continuidade, conformidade e supervisão humana.

O conteúdo é educacional. Requisitos legais, regulatórios, contratuais e técnicos devem ser confirmados em fontes oficiais e avaliados no contexto da organização, do setor, da jurisdição e do caso de uso.

2. Princípios fundamentais

Responsabilidade definida para negócio, tecnologia, dados, segurança, privacidade e risco.

Segurança e privacidade incorporadas desde a concepção até a desativação.

Controles proporcionais à criticidade, autonomia, alcance e sensibilidade dos dados.

Rastreabilidade de versões, avaliações, aprovações, exceções e incidentes.

Supervisão humana significativa para decisões de alto impacto.

3. Governança e responsabilidades

A direção aprova apetite de risco, prioridades, restrições e critérios de aceitação.

Um comitê multidisciplinar coordena negócio, tecnologia, segurança, privacidade, jurídico, compliance, auditoria, dados e terceiros.

A primeira linha implementa controles; a segunda linha define requisitos e desafia decisões; a auditoria fornece avaliação independente.

4. Inventário e classificação

Mantenha inventário de modelos, agentes, copilotos, APIs, dados, integrações e fornecedores.

Registre finalidade, proprietário, usuários, dados processados, localização, criticidade, dependências e status de aprovação.

Classifique o impacto sobre pessoas, operações, finanças, segurança, direitos, reputação e conformidade.

5. Avaliação de riscos

Defina contexto, ativos, ameaças, vulnerabilidades, impactos e controles existentes.

Avalie risco inerente e residual, incluindo viés, alucinação, vazamento de dados, abuso, indisponibilidade e dependência de terceiros.

Documente responsáveis, prazos, exceções e risco remanescente.

6. Dados e privacidade

Aplique minimização, limitação de finalidade, classificação, retenção, criptografia, mascaramento e prevenção de perda de dados.

Não envie segredos, credenciais, dados pessoais sensíveis ou propriedade intelectual a serviços não aprovados.

Valide origem, qualidade, representatividade e direitos de uso dos dados.

7. Identidade e acesso

Use identidade corporativa, MFA, menor privilégio e revisão periódica.

Separe desenvolvimento, teste e produção; restrinja chaves, tokens, endpoints e contas de serviço.

Proteja identidades de carga de trabalho e agentes e evite credenciais persistentes.

8. Desenvolvimento e aquisição segura

Defina requisitos antes da seleção, contratação ou desenvolvimento.

Avalie arquitetura, fluxo de dados, segurança do fornecedor, localização, suboperadores, exclusão e portabilidade.

Use revisão de código, análise de dependências, testes adversariais e validação de saídas.

9. Segurança específica de IA

Teste injeção de prompt, extração de instruções, vazamento de contexto, manipulação de recuperação, envenenamento de dados e abuso de ferramentas.

Limite ações de agentes por escopo, permissão, contexto, valor, frequência e aprovação humana.

Valide entradas e saídas e combine controles preventivos, detectivos, responsivos e de recuperação.

10. Monitoramento e métricas

Monitore disponibilidade, latência, erro, qualidade, deriva, segurança, uso indevido, custo, acesso e falhas de política.

Defina limites, alertas, responsáveis, triagem e critérios de interrupção.

Relatórios executivos devem destacar tendência, concentração de risco e ações pendentes.

11. Incidentes e continuidade

Integre incidentes de IA ao processo corporativo de resposta.

Prepare procedimentos para vazamento, comportamento inseguro, abuso, indisponibilidade e saída incorreta de alto impacto.

Mantenha capacidade de desativar recursos, revogar credenciais, substituir modelos e operar manualmente.

12. Terceiros e cadeia de suprimentos

Avalie fornecedores de modelos, dados, infraestrutura, conectores e observabilidade.

Inclua requisitos contratuais de segurança, privacidade, incidentes, continuidade, exclusão, portabilidade e subcontratação.

Mantenha estratégia de saída e teste de recuperação.

13. Evidências e auditoria

Conserve políticas, inventário, avaliações, diagramas, aprovações, testes, registros, exceções, contratos e incidentes.

As evidências devem ser atuais, rastreáveis e protegidas contra alteração indevida.

Auditorias devem verificar desenho e eficácia operacional.

Controles específicos da edição

- Defina contexto, escopo, política, objetivos, responsabilidades e critérios de risco.
- Integre planejamento, suporte, operação, avaliação de desempenho e melhoria.
- Use auditoria interna e análise crítica da direção para validar eficácia.

14. Checklist de aprovação antes da produção

Item	Status	Evidência/Responsável
Inventário e proprietário definidos	☐	
Classificação de impacto concluída	☐	
Avaliação de risco documentada	☐	
Revisão de privacidade concluída	☐	
Arquitetura e fluxo de dados aprovados	☐	
Identidades e acessos validados	☐	
Testes de segurança e uso indevido executados	☐	
Monitoramento e alertas configurados	☐	
Plano de resposta e continuidade aprovado	☐	
Risco residual formalmente aceito	☐	

15. Referências de verificação

- NIST AI Risk Management Framework
- ISO/IEC 42001:2023
- OWASP Top 10 for Large Language Model Applications
- MITRE ATLAS
- Documentação oficial do provedor e dos serviços utilizados
- Leis, regulamentos, contratos e políticas aplicáveis

16. Licença e contribuição

Salvo indicação em contrário, o conteúdo original é disponibilizado sob CC BY-NC-SA 4.0. Correções, melhorias de acessibilidade e comentários de tradução são bem-vindos pelo repositório.